

Security and Protection of Systems

Lecture 01 *Introduction to Information Security*

Dr. Zaher Haddad

ITNM3312, Security & Protection of Systems

Outlines

- Information Security Concepts
- Security Requirements
- Security Challenges
- Security Attacks
- Security Services
- Security Models

2

ITNM3312, Security & Protection of Systems

Outlines

- Information Security Concepts
- Security Requirements
- Security Challenges
- Security Attacks
- Security Services
- Security Models

3

ITNM3312, Security & Protection of Systems

What is Information Security?

- Measures to **deter**, **prevent**, **detect**, or **correct** security violations that involve the transmission of information.
- The protection afforded to an automated information system to attain the applicable objectives of preserving the Requirements of information system resources

4

ITNM3312, Security & Protection of Systems

The Importance of Information Security

1- Preventing data theft



2- Thwarting identity theft



3- Avoiding the legal consequences of not securing information



4- Maintaining productivity



5- Foiling cyberterrorism



ITNM3312, Security & Protection of Systems

Outlines

- Information Security Concepts
- Security Requirements
- Security Challenges
- Security Attacks
- Security Services
- Security Models

Security Requirements (CIA)



The CIA Security Triad



7

ITNM3312, Security & Protection of Systems

Security Requirements (CIA)

1. Confidentiality:

- Preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information.
- A loss of confidentiality is the unauthorized disclosure of information.



8

ITNM3312, Security & Protection of Systems

Security Requirements (CIA)-cont.

2- Integrity:

- Guarding against improper information modification or destruction, including ensuring information nonrepudiation and authenticity.
- A loss of integrity is the unauthorized modification or destruction of information.



9

ITNM3312, Security & Protection of Systems

Security Requirements (CIA)-cont.

3- Availability:

- Ensuring timely and reliable access to and use of information.
- A loss of availability is the disruption of access to or use of information or an information system.



10

ITNM3312, Security & Protection of Systems

Outlines

- Information Security Concepts
- Security Requirements
- Security Challenges
- Security Attacks
- Security Services
- Security Models

11

ITNM3312, Security & Protection of Systems

Challenges

1. Security is not as simple as it might first appear.
2. Successful attacks are designed by looking at the problem of a particular security mechanism or algorithm
3. The points in a network that need certain security mechanisms
 - This is true both in terms of physical placement

12

ITNM3312, Security & Protection of Systems

Challenges-cont.

6. The creation, distribution, and protection of that secret information *such as encryption key*.
7. Computer and network security is essentially a battle of wits between a perpetrator who tries to find holes and the designer or administrator who tries to close them.

13

ITNM3312, Security & Protection of Systems

Challenges-cont.

8. There is a natural tendency on the part of users and system managers to perceive little benefit from security investment until a security failure occurs
9. Security requires regular, even constant, monitoring, and this is difficult in today's short-term, overloaded environment.

14

ITNM3312, Security & Protection of Systems

Outlines

- Information Security Concepts
- Security Requirements
- Security Challenges
- Security Attacks
- Security Services
- Security Models

15

ITNM3312, Security & Protection of Systems

Security Attacks

- Security attack:
 - Any action that compromises the security of information owned by an organization
- Security mechanism
 - A process that is designed to detect, prevent, or recover from a security attack

ITNM3312, Security & Protection of Systems

Security Attacks

○ Security service

- A processing or communication service that enhances the security of the data processing systems and the information transfers of an organization
- Intended to counter security attacks, and they make use of one or more security mechanisms to provide the service

ITNM3312, Security & Protection of Systems

Security Attacks

Attack:

- An assault on system security that devices from an intelligence threat; that is , an intelligent act that is deliberate attempt (especially in the sense of method or technique) to evade security services and violate the security policy of a system

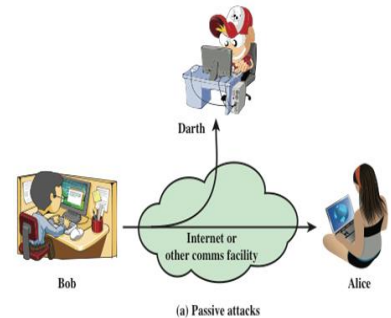
1. Passive attack

2. Active attack

ITNM3312, Security & Protection of Systems

Passive attack (1)

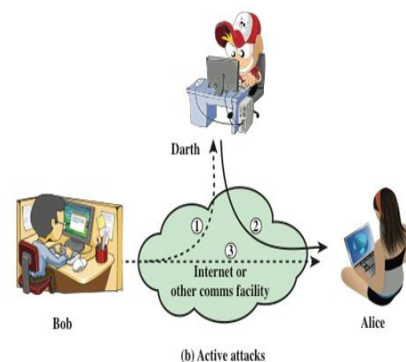
- A *passive attack* attempts to learn or make use of information from the system but does not affect system resources
- Are in the nature of eavesdropping on, or monitoring of, transmissions
- Goal of the opponent is to obtain information that is being transmitted
- Two types of passive attacks are:
 1. The release of message contents
 2. Traffic analysis



ITNM3312, Security & Protection of Systems

Active Attack (2)

- An *active attack* attempts to alter system resources or affect their operation
- Involve some modification of the data stream or the creation of a false stream
- Difficult to prevent because of the wide variety of potential physical, software, and network vulnerabilities
- Goal is to detect attacks and to recover from any disruption or delays caused by them

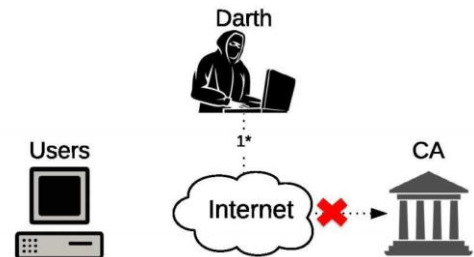


ITNM3312, Security & Protection of Systems

Active Attack (2)

1. Masquerade Attack:

- Takes place when one entity pretends to be a different entity
- Usually includes one of the other forms of active attack

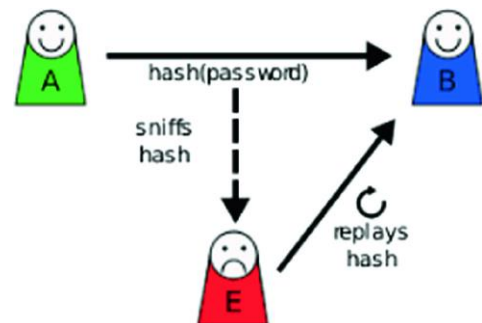


21

ITNM3312, Security & Protection of Systems

Active Attack (2)

- ### 2. Replay:
- Involves the passive capture of a data unit and its subsequent retransmission to produce an unauthorized effect

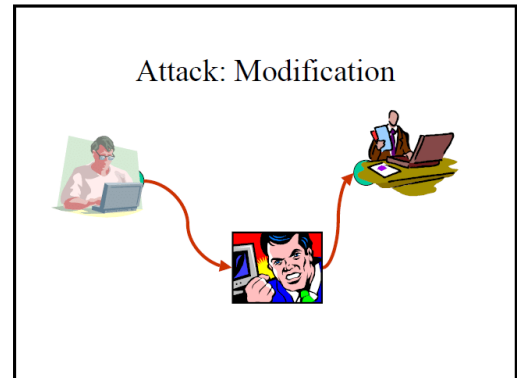


22

ITNM3312, Security & Protection of Systems

Active Attack (2)

3. **Modification of messages** : Some portion of a legitimate message is altered, or messages are delayed or reordered to produce an unauthorized effect

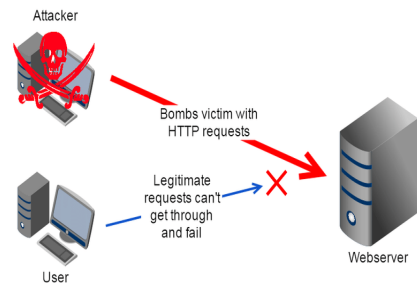


23

ITNM3312, Security & Protection of Systems

Active Attack (2)

4. **Denial of service**: Prevents or inhibits the normal use or management of communications facilities



24

ITNM3312, Security & Protection of Systems

Outlines

- Information Security Concepts
- Security Requirements
- Security Challenges
- Security Attacks
- Security Services
- Security Models

25

ITNM3312, Security & Protection of Systems

Security Services

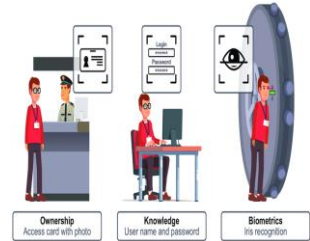
1. Authentication
2. Access Control
3. Data Confidentiality
4. Data Integrity
5. Nonrepudiation
6. Availability Service

26

ITNM3312, Security & Protection of Systems

Authentication (1)

- The process of recognizing a user's identity.
- It is the mechanism of associating an incoming request with a set of identifying credentials.
- The credentials provided are compared to those on a file in a database of the authorized user's information on a local operating system or within an authentication server.



ITNM3312, Security & Protection of Systems

Access Control (2)

- The ability to limit and control the access to host systems and applications via communications links
- To achieve this, each entity trying to gain access must first be identified, or authenticated, so that access rights can be tailored to the individual



28

ITNM3312, Security & Protection of Systems

Confidentiality (3)

- The protection of transmitted data from passive attacks
 - Broadest service protects all user data transmitted between two users over a period of time
 - Narrower forms of service includes the protection of a single message or even specific fields within a message
- The protection of traffic flow from analysis
 - This requires that an attacker not be able to observe the source and destination, frequency, length, or other characteristics of the traffic on a communications facility

29

ITNM3312, Security & Protection of Systems

Data Integrity (4)

- The maintenance of, and the assurance of, data accuracy and consistency of transmitted data
- Any unintended changes to data as the result of a storage, retrieval or processing operation, including malicious intent, unexpected hardware failure, and human error, is failure of data integrity.
- If the changes are the result of unauthorized access, it may also be a failure of data security.



30

ITNM3312, Security & Protection of Systems

Non-repudiation (5)

- Prevents either sender or receiver from denying a transmitted message
- When a message is sent, the receiver can prove that the alleged sender in fact sent the message
- When a message is received, the sender can prove that the alleged receiver in fact received the message



ITNM3312, Security & Protection of Systems

Availability (6)

- Protects a system to ensure its availability
- This service addresses the security concerns raised by denial-of-service attacks
- It depends on proper management and control of system resources and thus depends on access control service and other security services

32

ITNM3312, Security & Protection of Systems

Outlines

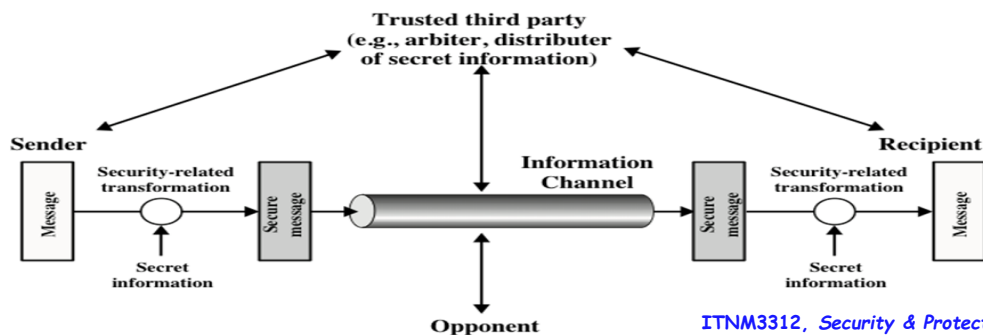
- Information Security Concepts
- Security Requirements
- Security Challenges
- Security Attacks
- Security Services
- Security Models

33

ITNM3312, Security & Protection of Systems

Example 1: Network Security Model

- A message is to be transferred from one party to another across some sort of Internet service.
- The two parties, who are the principals in this transaction, must cooperate for the exchange to take place by using logical connection..



ITNM3312, Security & Protection of Systems

Example 1: Network Security Model

- **Examples** include the encryption of the message, which scrambles the message so that it is unreadable by the opponent, and the addition of a code based on the contents of the message, which can be used to verify the identity of the sender.
- Some secret information shared by the two principals and, it is hoped, Unknown to the opponent.

35

ITNM3312, Security & Protection of Systems

Example 1: Network Security Model

- An example is an encryption key used in conjunction with the transformation to scramble the message before transmission and unscramble it on reception.
- A trusted third party may be needed to achieve secure transmission. For example, a third party may be responsible for distributing the secret information to the two principals while keeping it from any opponent.
- Or a third party may be needed to arbitrate disputes between the two principals concerning the authenticity of a message transmission.

36

ITNM3312, Security & Protection of Systems

Example 1: Network Security Model

This general model shows that there are four basic tasks in designing a particular security service:

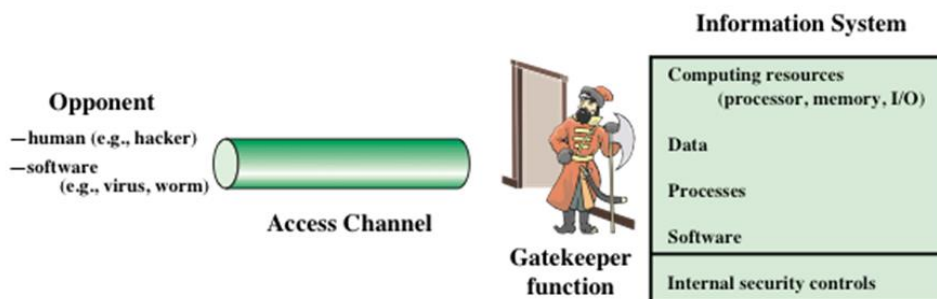
1. Design an algorithm for performing the security-related transformation.
 - The algorithm should be such that an opponent cannot defeat its purpose.
2. Generate the secret information to be used with the algorithm.
3. Develop methods for the distribution and sharing of the secret information.
4. Specify a protocol to be used by the two principals that makes use of the security algorithm and the secret information to achieve a particular security service.

37

ITNM3312, Security & Protection of Systems

Example 2: Network Access Security Model

A general model of these other, which reflects a concern for protecting an information system from unwanted access.



38

ITNM3312, Security & Protection of Systems

Example 2: Network Access Security Model

- Most readers are familiar with the concerns caused by the existence of hackers, who attempt to penetrate systems that can be accessed over a network.
- The hacker can be someone who, with no malign intent, simply gets satisfaction from breaking and entering a computer system.
- The intruder can be a disgruntled employee who wishes to do damage or a criminal who seeks to exploit computer assets for financial gain (e.g., obtaining credit card numbers or performing illegal money transfers).

39

ITNM3312, Security & Protection of Systems

Thanks

ITNM3312, Security & Protection of Systems